

Phish-Defender AI – Scoring System Explained

This document describes exactly how the Phish-Defender AI backend computes its **final risk score** and **classification label**. Every statement below is derived from the actual codebase behavior.

1. Domain Similarity Agent

Purpose: Detects brand impersonation, typosquatting, homograph attacks, and phishing-keyword patterns in the domain name itself.

Score range: 0.0 to 1.0

Signals considered:

- **Known alias short-circuit** — If the domain is a recognized sub-brand or alternate TLD of a known organization (e.g. `discord.gg` → `discord.com`, `github.io` → `github.com`), the agent immediately returns a risk score of **0.0** and marks the brand as detected. No further analysis is performed.
- **Exact brand match** — If the registrable domain exactly matches a known brand's canonical domain (same domain AND same TLD suffix), risk is **0.0**.
- **Brand containment** — If a known brand name is embedded inside the domain string (but the domain is not the brand itself), this contributes **+0.50** to risk. Short brands (≤ 3 characters) must appear as standalone segments separated by hyphens, underscores, or dots to avoid spurious substring matches.
- **Fuzzy similarity** — A multi-algorithm approach compares the normalized domain against every known brand using three metrics: full string ratio, partial ratio (brands ≥ 4 chars only), and token-sort ratio. The best combined score is used. A dynamic confidence threshold discards weak matches: brands ≤ 4 characters need $\geq 75\%$ similarity, longer brands need $\geq 65\%$. The similarity score then maps to risk non-linearly:
 - ≥ 0.85 → **+0.75**
 - ≥ 0.70 → **+0.40**
 - ≥ 0.50 → **+0.20**
 - < 0.50 → score $\times 0.2$ (very low contribution)
- **Phishing keywords in domain** — Words like "login", "secure", "verify", "account" in the domain name add risk: one keyword → **+0.05**, two or more → **+0.15**. If a brand is detected AND phishing

keywords are present, an additional **+0.10** is added.

- **Brand tier bonus** — High-value target brands (global finance, EU finance, major tech/social) receive an additional tier-based boost: finance EU → **+0.15**, finance global → **+0.10**, tech/social → **+0.05**.
- **Unicode homoglyph normalization** — Before any comparison, the domain is normalized by replacing Cyrillic confusables, IPA look-alikes, and ASCII substitutions (e.g. `0→o` , `1→l` , `@→a`) with their Latin equivalents.

Output: A risk score, similarity score, detected brand name (if any), and closest matching brand.

2. Domain Intelligence Agent

Purpose: Evaluates the domain's infrastructure — registration age, DNS health, SSL validity, WHOIS data — to assess whether it has the characteristics of a throwaway phishing domain.

Score range: 0.0 to 1.0

Signals considered (graduated, non-binary):

- **Domain age** (primary signal, tiered):
 - < 7 days → **0.50** (brand new, very high risk)
 - < 30 days → **0.35**
 - < 90 days → **0.15**
 - < 365 days → **0.05**
 - ≥ 365 days → **0.00**
 - Unknown (WHOIS failed) → **0.15** (mild penalty, not punitive)
- **SSL certificate validity:**
 - Valid SSL present → **-0.05** (or **-0.10** if WHOIS age is unknown)
 - No valid SSL → **+0.15**
- **WHOIS privacy:**
 - Privacy enabled on a new domain (< 30 days) → **+0.15**
 - Privacy enabled on an older domain → **+0.05**
- **No MX records** → **+0.10**
- **Low nameserver count** (≤ 1) → **+0.10**
- **Short registration span** (creation-to-expiry < ~13 months) → **+0.10**
- **DNSSEC present** → **-0.05**
- **Hosted platform detection** — The agent also identifies whether the domain belongs to a known free hosting/PaaS platform (e.g. `vercel.app` , `netlify.app` , `herokuapp.com`). This flag does not directly affect the Intelligence risk score but is passed downstream and heavily influences the Decision Agent's weight redistribution and combo multipliers.

Output: Risk score plus structured flags (is_new_domain, is_hosted_platform, ssl_valid, etc.).

3. Website Content Agent

Purpose: Downloads and parses the actual page HTML (using Playwright for JS-rendered content with HTTP fallback), then extracts phishing-related signals from the DOM.

Score range: 0.0 to 1.0

Signals considered:

- **Structural / Form signals:**
 - Login form detected (includes password fields, obfuscated input names, or standalone credential inputs without `<form>` wrappers) → **+0.40**
 - Bare password field without form context → **+0.20**
 - "Lonely form" pattern (1-2 inputs + button + `< 3` links + `< 100` words – classic minimalist phishing checkpoint) → **+0.40**
 - Cross-domain form submissions → **+0.35**
 - Multiple forms → **+0.05**
 - Excessive hidden inputs (`> 3`) → **+0.05**
- **Title analysis:**
 - Page title contains phishing-related keywords ("secure", "login", "auth", "verify", "account", "webmail", "reward") → **+0.20**
- **Brand impersonation (content-level):**
 - Context-aware detection that checks page title, headings, visible text, image alts, and meta tags for known brand names. Applies domain alias awareness (bing.com mentioning "microsoft" is not impersonation), ambiguous brand word filtering, SSO brand filtering, and a body-text-only threshold (non-prominent brands need ≥ 2 mentions).
 - ≥ 2 impersonated brands detected → **+0.15**
 - 1 impersonated brand → **+0.10**
 - (Note: primary brand impersonation scoring has been delegated to the Cross-Reference Engine; the content agent retains a reduced signal for graceful degradation.)
- **Payment/credit card collection** – Detected via input field attributes, payment iframes (Stripe, Braintree), and visible text phrases → **+0.45**
- **Tech support scam indicators:**
 - ≥ 3 scam keywords matched → **+0.60**
 - ≥ 1 scam keyword → **+0.35**
 - Toll-free phone numbers adjacent to scare text are also flagged.
- **OTP / verification code page** → **+0.25**
- **URL path risk:**
 - Suspicious path segments (/checkpoint, /verify, /auth, /login, etc.) → up to **+0.30**
 - High-entropy long paths (`> 10` chars, entropy `> 4.0`) → additional **+0.20**
- **JavaScript obfuscation:**

- Packed/eval obfuscation patterns → up to **+0.30**
- Base64-encoded payloads with heavy hex escapes → **+0.20**
- Scripts loaded from suspicious CDNs (pastebin, raw GitHub, worker.dev) → **+0.25**
- JS risk is capped at **0.40**
- **Other signals:** Suspicious iframes (**+0.10**), meta-refresh or JS redirects (**+0.05**), external scripts > 5 (**+0.05**), suspicious content keywords (up to **+0.15**)
- **Provider blocklist** — If a URL shortener (TinyURL, bit.ly, etc.) has its own block page active, risk is forced to **1.0** immediately.
- **Legitimate app behavior** — A flag set when the page has no login forms, no suspicious keywords, no payment/scam/OTP signals, no cross-domain forms, no suspicious iframes, no redirects, minimal hidden inputs, and a meaningful page title. This flag is used by the Decision Agent for graceful score reduction.

Output: Risk score plus a rich set of structured signals (login/password detection, brand impersonation list, payment detection, scam indicators, final URL after redirects, etc.).

4. Safe Browsing Agent

Purpose: Queries Google's Safe Browsing API v4 to check if the URL is in Google's known-malicious database.

Score range: 0.0 or 1.0 (binary)

Signals considered:

- The URL is submitted to the Safe Browsing API against four threat types: MALWARE, SOCIAL_ENGINEERING, UNWANTED_SOFTWARE, and POTENTIALLY_HARMFUL_APPLICATION.
- **If any threat match is returned:** `is_safe = false`, `risk_score = 1.0`
- **If no threat match:** `is_safe = true`, `risk_score = 0.0`

Resilience mechanisms:

- **Fail-open policy** (default): If the API key is missing, the circuit breaker is open, or the API call fails, the agent returns `is_safe = true` with `risk_score = 0.0` and marks itself as disabled. This prevents an API outage from blocking legitimate URLs.
- **Circuit breaker:** After 3 consecutive failures, the agent stops making API calls for 60 seconds, then allows a probe request (half-open state).
- **Retry with backoff:** One retry on 502/503 errors.

Output: Binary safe/unsafe flag, risk score, threat match details, and disabled flag.

5. PhishTank Agent

Purpose: Checks the URL against a locally cached copy of the PhishTank community-maintained phishing database.

Score range: 0.0 or 0.8 (binary-ish)

Signals considered:

- The URL is normalized (scheme stripped, path and query preserved) and checked against an in-memory set of known phishing URLs loaded from PhishTank's `online-valid.json.gz` dataset.
- **If found:** `is_phishing = true`, `risk_score = 0.8` (high risk but not 1.0 — PhishTank is community-curated, not an authoritative API like Safe Browsing)
- **If not found:** `is_phishing = false`, `risk_score = 0.0`

Freshness: The dataset is refreshed hourly in a background thread. If the cache is missing at startup, a background download is initiated immediately. User requests are never blocked by a refresh.

Output: Phishing flag, risk score, and disabled flag.

6. Cross-Reference Engine

Purpose: Correlates signals *across* the Similarity, Intelligence, and Content agents to detect brand impersonation patterns that no single agent can identify in isolation. Runs **AFTER** all analysis agents but **BEFORE** the Decision Agent.

Score range: 0.0 to 1.0

Inputs consumed:

- Brand impersonation brands detected in page content (from Content Agent)
- Brand detected in domain name (from Similarity Agent)
- Hosted platform flag and domain age (from Intelligence Agent)
- Login/password form presence (from Content Agent)
- Payment form presence (from Content Agent)
- Scam indicator count (from Content Agent)
- SSL validity (from Intelligence Agent)

Domain alias filtering: Before any checks, the engine filters out brand mentions that belong to the same organization as the page domain (using the brand-domain alias table). For example, `youtube.com` mentioning "google" is not a mismatch.

Correlation checks and risk levels (using max-of semantics – each check sets a floor):

Scenario	Risk Score
Tier 1: Hosted brand impersonation – Brand in content AND brand in domain name AND hosted platform, AND domain is NOT established	0.90
Tier 1 on established domain – Same as above but domain is > 2 years old with valid SSL	0.35 (demoted)
Tier 2: Brand-content mismatch – Brand mentioned in page content but domain doesn't match	0.35
Tier 3: Brand-domain mismatch – Brand name embedded in domain but on a hosted platform	0.55
Brand impersonation + credential collection on untrusted domain (new, hosted, or no SSL)	0.80
Brand impersonation + credential collection on established domain	No risk increase (suppressed)
Payment form on new or hosted domain	0.70
Scam indicators (≥ 2) on new or hosted domain	0.65

Established domain trust discount: For domains older than 2 years with valid SSL (and not new/hosted), a flat **-0.15** discount is applied to the CRE risk score.

Output: A dict containing boolean flags for each mismatch type, the list of detected content brands, and the composite `cross_ref_risk_score`.

7. Decision Agent (CORE – Final Score Calculation)

Purpose: Aggregates all upstream agent outputs and the Cross-Reference Engine result to produce the **final risk score**, **classification label**, **confidence level**, and **severity**.

7.1 Trust Anchor Breaking (Pre-Processing)

Before any scoring begins, the Decision Agent checks for a specific attack pattern: a trusted domain (low intelligence risk < 0.15) that has been compromised and is serving content via deep, high-entropy randomized URL paths.

- **Trigger:** Intelligence risk < 0.15, AND the final URL's path has Shannon entropy > 4.2, AND the path has ≥ 3 segments.
- **Effect:** The intelligence risk score is **overwritten to 0.50**, neutralizing the false trust signal from the domain's age and infrastructure.

7.2 Safe Browsing Override (Early Exit)

If Google Safe Browsing flagged the URL as malicious(`is_safe = false`):

- The final risk score is set to **1.0**
- Classification is set to **PHISHING**
- Confidence is **HIGH**
- Severity is **CRITICAL**
- All further scoring logic is skipped – the function returns immediately

This is the highest-priority override in the entire system.

7.3 Weighted Score Calculation (Normal Path)

The system uses **three different weight sets** depending on which agents have signal:

Condition A – Safe Browsing has a non-zero risk score:

Agent	Weight
Similarity	0.25
Intelligence	0.20
Content	0.20
Safe Browsing	0.35

Condition B – Safe Browsing risk is 0.0, AND Cross-Reference Engine has a non-zero score:

Agent	Weight
Similarity	0.20
Intelligence	0.20
Content	0.30
Cross-Reference	0.30

Condition C – Safe Browsing risk is 0.0, AND Cross-Reference Engine has no signal:

Agent	Weight
Similarity	0.30
Intelligence	0.30
Content	0.40

Hosted platform weight redistribution: When the domain is on a known hosting platform, Intelligence Agent's weight is drastically reduced (it provides little signal for shared hosts), and that weight is redistributed to Content and Similarity (or Cross-Reference when available). Specifically:

- In Condition B: Intelligence drops to **0.05**, Similarity → **0.25**, Content → **0.35**, CRE → **0.35**
- In Condition C: Intelligence drops to **0.10**, Similarity → **0.40**, Content → **0.50**

The base score is calculated as the weighted sum of the selected agents' individual risk scores.

7.4 Combo Multipliers (Deadly Phishing Signatures)

After the weighted score, the Decision Agent applies additive bonuses for dangerous signal *combinations* that are near-certain indicators of phishing:

Combo	Condition	Boost
New Domain + Login Form	Domain < 30 days AND login/password form detected	+0.20
Hosted + Login + Brand Similarity	Hosted platform AND login form AND similarity score > 0.60	+0.25
Impersonation on Hosted Platform	Similarity score > 0.60 AND hosted platform	+0.20
Open Redirect with Login	Final domain differs from input domain (different root) AND login form detected AND NOT a known brand-family redirect	+0.35
Provider Blocklisted	URL shortener/provider explicitly blocked the link	Score forced to 1.0
Very High Similarity	Similarity risk ≥ 0.75 AND NOT a known alias	+0.20
Login + Suspicious Intelligence	Login form AND intelligence risk ≥ 0.40	+0.15

Known alias protection: Combos 4 and 6 are suppressed if the Similarity Agent identified the domain as a known alias (risk = 0.0 with a brand detected). This prevents false positives on legitimate sub-brands.

7.5 PhishTank Override

If PhishTank flagged the URL as phishing:

- The score is floored at **0.54** (raised to ensure it crosses the PHISHING threshold for new/hosted domains)
- This is a `max()` operation – it only raises the score, never lowers it

- PhishTank is not as authoritative as Safe Browsing, so it doesn't force the score to 1.0

7.6 Graceful Degradation (Positive Signals)

The Decision Agent applies score *reductions* when positive signals are present:

- **Legitimate app behavior + valid SSL + no agent flagging high risk (≥ 0.40) + no critical signals:**
Score **-0.15**
- **Legitimate app behavior only (no SSL or some risk):** Score **-0.08**
- These reductions are suppressed entirely for hosted platforms and provider-blocklisted domains (they have zero inherent phishing defense)
- **Established domain trust bonus:** Domains older than 2 years with valid SSL, not new, not hosted, and without critical signals get a **-0.10** discount

7.7 Corroboration Boost (Signal Amplification)

When **2 or more** agents (out of Similarity, Intelligence, Content, and Cross-Reference) report risk ≥ 0.40 :

- The score is multiplied by **1.25** (25% boost)
- This rewards signal agreement – multiple independent indicators converging on high risk
- The result is capped at 1.0

7.8 Network State Cap

If the pipeline determined that the target is network-blocked (HTTP 401/403/405), the score is capped at **0.60** maximum. This prevents inflated scores when agents couldn't fully analyze the content due to access restrictions.

7.9 Final Score Clamping

The score is clamped to the range `[0.0, 1.0]`.

8. Final Classification

The final score maps to a classification label via threshold comparison. The thresholds are **context-sensitive**:

Base Thresholds

Classification	Score Threshold
PHISHING	≥ 0.55
SUSPICIOUS	≥ 0.35
SAFE	< 0.35

Adjusted Thresholds for Untrusted Domains

For **new domains** (< 30 days) or **hosted platform** subdomains, the PHISHING threshold is lowered to **0.45**. This means untrusted domains need less evidence to be classified as phishing.

UNKNOWN Classification

The UNKNOWN label is only returned when:

- The final score is **below** the SUSPICIOUS threshold (< 0.35), AND
- The network state was degraded (BLOCKED, UNREACHABLE, or ERROR)

This means the system acknowledges it genuinely had insufficient signal to make a determination. A score ≥ 0.35 from non-content agents is never overridden to UNKNOWN – the system trusts its computed score.

9. Confidence and Severity

Confidence (score-based, not label-based)

Label	Condition
HIGH	SAFE with score < 0.10, OR PHISHING with score $\geq$ threshold + 0.15
MEDIUM	SAFE with score $\geq$ 0.10, OR PHISHING below the HIGH threshold, OR SUSPICIOUS above its midpoint
LOW	UNKNOWN, OR SUSPICIOUS below its midpoint

Severity (5-tier)

Level	Condition
CRITICAL	Safe Browsing flagged (authoritative)
HIGH	PHISHING with score $\geq$ threshold + 0.15

Level	Condition
MEDIUM	PHISHING (lower confidence)
LOW	SUSPICIOUS
INFO	SAFE or UNKNOWN

10. Special Cases

Early Pipeline Exits

- **Confirmed malicious (early exit):** If Safe Browsing or PhishTank returns a risk ≥ 0.90 before the content agent runs, the pipeline skips Playwright-based content analysis entirely. The content agent is given a default result with `risk_score = 1.0`. This saves significant processing time.
- **Network unreachable/blocked:** If the pre-flight network check finds the target is BLOCKED, UNREACHABLE, or in ERROR state, the content agent is skipped. For BLOCKED specifically, the content result is flagged as `is_provider_blocklisted = true`.

Degraded Agent Handling

- Each agent runs in a daemon thread with a hard timeout of 7 seconds, further constrained by the 30-second total pipeline deadline.
- If any agent times out or throws an exception, it returns **safe defaults**: risk score 0.0, no flags set. The agent is recorded as "degraded" in the pipeline metadata.
- The pipeline continues with whatever agents succeeded. This is a fail-open design — missing data never artificially inflates risk.

Content Agent Deadline Awareness

- If less than 40% of the pipeline's time budget remains when the content agent would start, it is skipped entirely to avoid deadline violations.
 - The content agent's own timeout is dynamically calculated as `min(15s, remaining_time - 2s)`, with a floor of 3 seconds.
-

11. Summary of Overall Scoring Flow

1. **Input normalization** — The pipeline cleans the domain/URL and evaluates network reachability.

2. **Parallel agent execution** – Similarity, Intelligence, Safe Browsing, and PhishTank agents run concurrently in daemon threads with hard timeouts.
3. **Content analysis** – The content agent runs sequentially (it depends on network state and can be skipped if malicious is already confirmed).
4. **Cross-Reference correlation** – The CRE synthesizes signals from Similarity, Intelligence, and Content to detect brand impersonation patterns that span agent boundaries.
5. **Decision Agent aggregation:**
 - Trust Anchor Breaking check (compromised trusted domains)
 - Safe Browsing override (immediate PHISHING at 1.0 if flagged)
 - Dynamic weight selection (3 weight sets based on available signals)
 - Hosted platform weight redistribution
 - Combo multipliers for deadly phishing signatures
 - PhishTank floor enforcement
 - Graceful degradation (legitimate app / established domain discounts)
 - Corroboration boost (25% amplification when ≥ 2 agents agree)
 - Network state cap
 - Score clamping to [0.0, 1.0]
6. **Classification** – Score mapped to PHISHING / SUSPICIOUS / SAFE / UNKNOWN using context-sensitive thresholds.
7. **Confidence and Severity** – Derived from the score magnitude and classification label.
8. **Pipeline metadata** – Agent timings, degraded agents, and errors are attached for observability.